

Designing the Hierarchy of Trust

Red Hat Lessons from CVE Program Governance

Yogesh Mittal

PSIRT Manager, Red Hat



Red Hat
Product Security

What we'll discuss today

- ▶ The Context: The Scaling Challenge (NVD & CRA)
- ▶ The Blueprint: Red Hat's "Hierarchy of Trust" Model in CVE Program
- ▶ The Future: A Proposal for GVIP & Europe



The Strategic Conflict

The New Landscape

- EU Cyber Resilience Act (CRA)
- 24-Hour Reporting Mandates
- Explosion of Vulnerability Volume

"Hub-and-Spoke" Trap

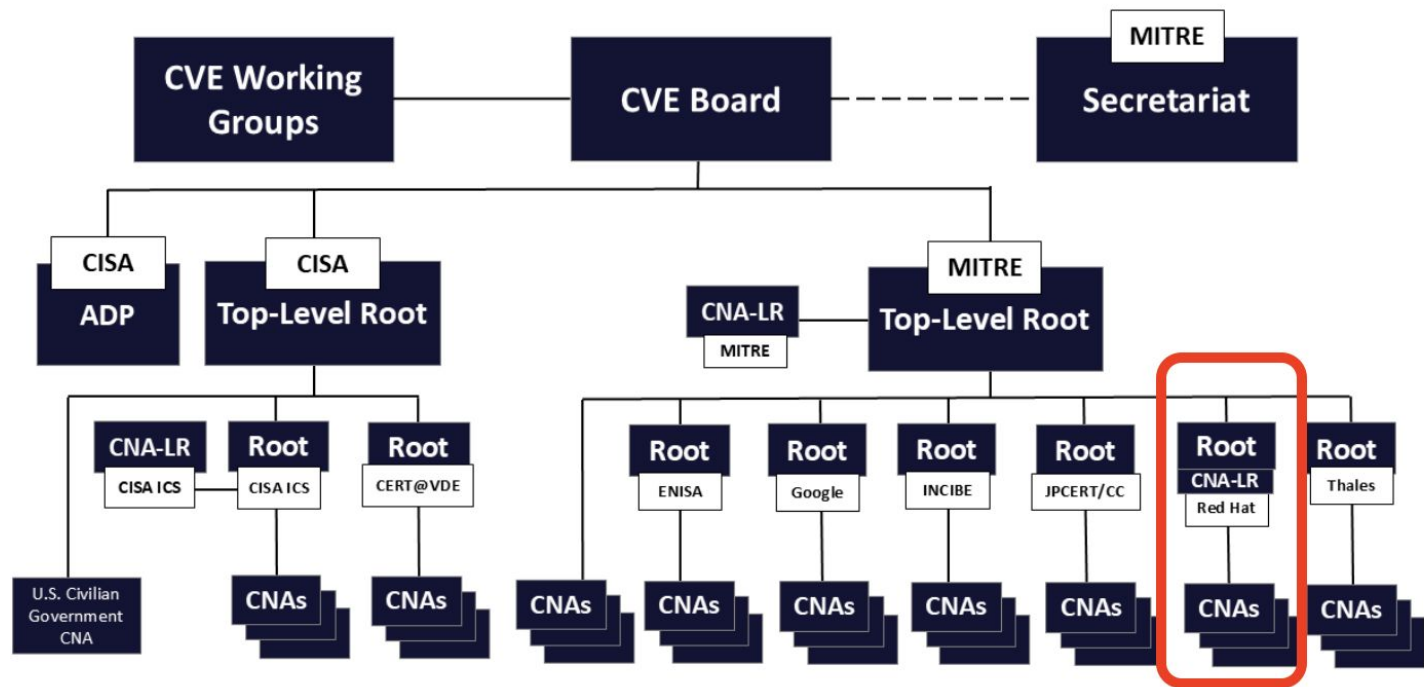
- Centralized databases (like NVD) create single points of failure.
- Bottlenecks slow down critical intelligence.

The Challenge

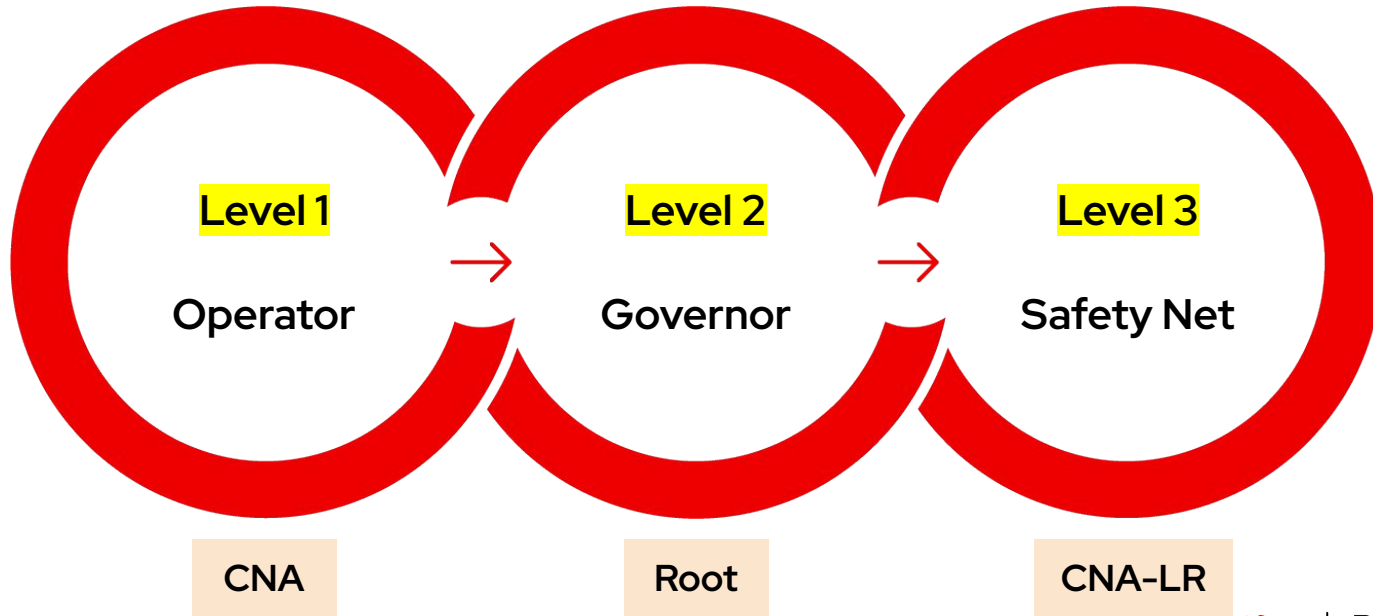
How do we achieve Global Speed without sacrificing Local Sovereignty?



Structure



The Governance Blueprint

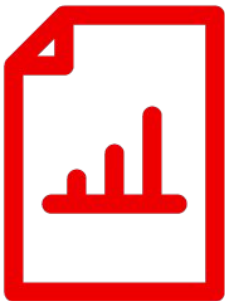


Level 1 – The Operator

Vendor/Maintainer

Core Principle

Closest to the Code



The Rule

The Maintainer must own the assessment

Why

Overruling vendors on severity destroys trust and data quality

CRA Implication

Systems must be "Provider-Driven," not "Central-Assessment-Driven"



Level 2 – The Governor

The Root Model

Core Principle

Scale through Federation



The Shift

From "Policing Data" to "Governing Process"

Red Hat's Experience

Verify CNAs follow process, don't verify every bug in OSS

Application

National CSIRTs should act as "Roots," not "Databases"

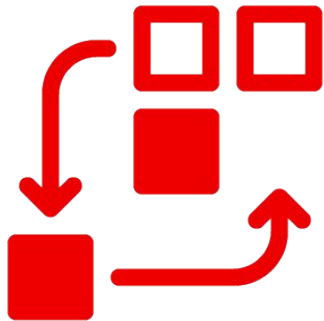


Level 3 - The Safety Net

CNA-LR Model

Core Principle

No dead ends



The Gap

What happens when a vendor goes bankrupt or disappears?

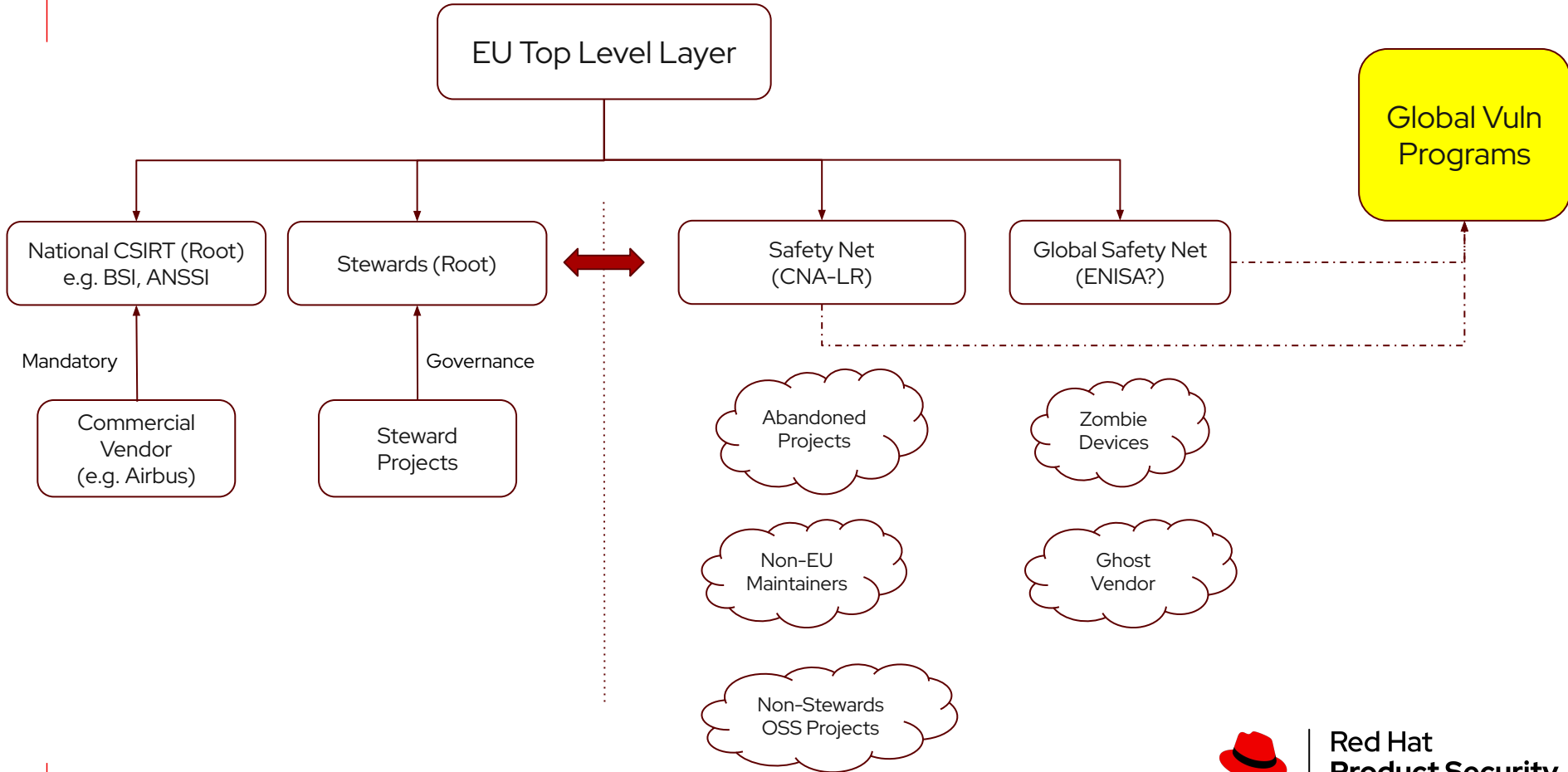
The solution

The CNA of Last Resort (CNA-LR)

Function

A designated body to adopt "orphaned" vulnerabilities to ensure the ecosystem stays informed



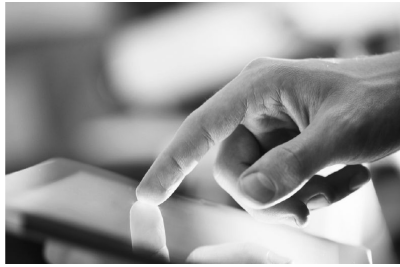


Recommendations for GVIP



Federate, Don't Centralize

Empower Roots (National/Sector leads) to make final decisions



Institutionalize the Safety Net

Formally define the "Last Resort" role for Europe



Design for Horizontal Collaboration

Build channels for Roots to talk to Roots and leverage Safety Nets' expertise



Thank you

Red Hat is the world's leading provider of enterprise open source software solutions. Award-winning support, training, and consulting services make Red Hat a trusted adviser to the Fortune 500.



linkedin.com/company/red-hat



facebook.com/redhatinc



youtube.com/user/RedHatVideos



twitter.com/RedHat



Red Hat
Product Security